

Manuel du processus de traitement

Du signalement a la cloture du dossier

Workflow complet, roles metiers, actions et delais

Citoyen sans compte | Chercheur en securite | Chercheur Bug Bounty

Sommaire

Sommaire	1
1. Objet du manuel	3
A qui il s'adresse	3
Conventions	3
2. Le processus en une page	4
Le parcours nominal d'un dossier	4
Ce qui se déclenche sans intervention humaine	4
3. Les acteurs et leurs droits	5
3.1 Les quatre familles	5
3.2 Ce que chaque rôle fait dans le processus	5
3.3 Qui peut faire quoi	5
4. Avant le premier signalement	7
4.1 Ce que le public voit et qui le prépare	7
4.2 Créer une organisation	7
4.3 Créer un programme : VDP ou Bug Bounty	7
4.4 Fixer les délais	8
5. Le signalement : trois portes d'entrée	9
5.1 Le citoyen sans compte	9
5.2 Le chercheur en sécurité inscrit	9
5.3 Le chercheur Bug Bounty	10
5.4 Les deux autres canaux	10
5.5 Ce que la plateforme fait à la seconde du dépôt	10
6. Le traitement, étape par étape	12
6.1 Table des passages autorisés	15
7. La branche Bug Bounty : la récompense	17
7.1 Qui fait quoi	17
7.2 D'où vient le montant proposé	17
7.3 Cycle de vie de la récompense	17
7.4 Le paiement	18
8. Divulgation, publication et clôture	19
9. Cas particuliers et issues alternatives	21
9.1 Le déclarant ne répond plus	21
9.2 Doubleton : ce que le déclarant apprend, et ce qu'il n'apprend pas	21

9.3 Rapport chiffré PGP	21
9.4 Le déclarant est anonyme et injoignable	21
9.5 Pièces jointes refusées	21
9.6 Un signalement qui ne vise aucune organisation référencée	21
9.7 Reprendre un dossier clos	21
10. Délais, priorités et écrans de pilotage	22
10.1 Les cinq échéances et leur cycle	22
10.2 Le score de priorité	22
10.3 Où travailler, selon le rôle	22
10.4 Exports	23
11. Échanger sur un dossier	24
11.1 Les trois niveaux de confidentialité	24
11.2 Qui est prévenu, et quand	24
11.3 Pièces jointes	24
12. Ce que voit le déclarant	25
Ce que le déclarant ne voit jamais	25
Sa réputation, s'il est inscrit	25
13. Trois parcours de bout en bout	26
13.1 Un citoyen signale un site ministériel	26
13.2 Un chercheur inscrit, dossier publié avec CVE	27
13.3 Un chercheur Bug Bounty récompense	28
14. Traçabilité et contrôle	29
Cinq règles que la plateforme fait respecter d'elle-même	29
A. Les états du dossier	30
B. Ce qui se règle sans toucher au code	31
Pour aller plus loin	31

LIRE CE DOCUMENT

1. Objet du manuel

Ce manuel décrit le traitement d'un signalement de vulnérabilité sur eVDP, depuis le moment où une personne découvre une faille jusqu'à la clôture du dossier. Il répond à trois questions pour chaque étape : **qui agit, à quel moment, et quel effet** son action produit sur le dossier et sur les personnes qui le suivent.

Il couvre les trois profils de déclarant que la plateforme accepte - un citoyen sans compte, un chercheur en sécurité inscrit, un chercheur participant à un programme Bug Bounty - et les rôles métiers qui interviennent ensuite.

A qui il s'adresse

Lecteur	Ce qu'il y trouve	Chapitres
Agent de triage, analyste CSIRT	La séquence de traitement quotidienne, les délais à tenir, les écrans et les actions correspondantes.	5 à 9
Coordinateur national	Les décisions qui lui sont réservées : approbation d'une récompense, publication d'un advisory, arbitrage des délais.	8, 9, 13
DSI, responsable d'organisation	Ce qu'on attend de son entité une fois contactée, et dans quels délais.	7, 10, 12
Déclarant (citoyen, chercheur)	Comment signaler, ce qu'il reçoit en retour, ce qu'il peut suivre.	4, 5, 12
Auditeur, direction	La chaîne de responsabilité, la traçabilité et les indicateurs.	3, 11, 13

Conventions

- Les **capacités** sont citées telles qu'elles figurent dans la plateforme, en majuscules : **TRIAGE_CASE**, **APPROVE_BOUNTY**. Une capacité est l'autorisation élémentaire vérifiée par le serveur ; un rôle en est un ensemble.
- Les **statuts de dossier** sont cités en majuscules : **VALIDATED**, **FIX_VERIFIED**. Leur libellé français est celui affiché à l'écran.
- Les **écrans** sont désignés par leur adresse : **/cases/kanban/**, **/bounties/**. Le menu latéral y mène selon le rôle.
- Un **dossier** porte la référence **EVDP-AAAA-NNNNNN**. C'est l'objet de travail ; le **rapport** est la matière brute déposée par le déclarant, que le traitement ne modifie jamais.

Deux règles valables partout dans ce manuel

- Le rôle n'est jamais lu depuis le navigateur.** Il vient de la base de données, et chaque action est revérifiée par le serveur. Une entrée de menu absente n'est pas une simple mise en forme : l'adresse saisie à la main est refusée de la même façon, et le refus est journalisé.
- Un dossier est privé par défaut.** Rien n'est publié automatiquement, à aucune étape. La publication est un acte explicite, réservé à un rôle précis, et elle porte sur un advisory rédigé pour l'occasion - jamais sur le rapport d'origine.

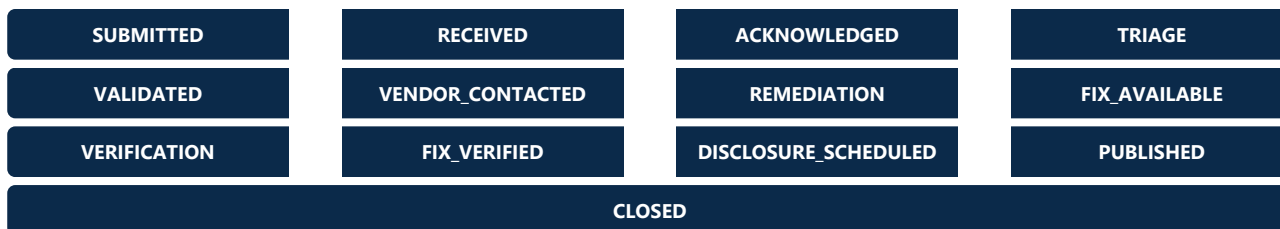
VUE D'ENSEMBLE

2. Le processus en une page

Six phases séparent la découverte d'une faille de la clôture de son dossier. Les deux premières appartiennent au déclarant et à l'équipe de triage, les trois suivantes à la coordination et à l'organisation affectée, la dernière à la publication.

Phase	Qui agit	Délai vise	État à la sortie
1. Signalement Le déclarant dépose son rapport	Citoyen, chercheur, chercheur Bug Bounty	-	SUBMITTED
2. Réception Prise en charge et accusé de réception	Agent de triage, analyste CSIRT	72 heures	RECEIVED puis ACKNOWLEDGED
3. Triage Qualification technique et décision	Agent de triage, analyste CSIRT, coordinateur	5 jours	VALIDATED, ou une issue de triage
4. Coordination L'organisation affectée est contactée	Analyste CSIRT, coordinateur ; réponse de la DSI	7 jours pour la réponse	VENDOR_CONTACTED, VENDOR_ACKNOWLEDGED
5. Remédiation Correction puis vérification	DSI et responsable d'organisation, avec l'analyste	30 à 90 jours selon la sévérité	FIX_AVAILABLE puis FIX_VERIFIED
6. Divulgestion Advisory rédigé, relu, publié	Analyste CSIRT puis coordinateur national	90 jours après validation, par défaut	DISCLOSURE_SCHEDULED, PUBLISHED, CLOSED

Le parcours nominal d'un dossier



Toute transition non prévue est refusée par le serveur et tracée comme un refus dans le journal d'audit. Le chapitre 6 donne la table complète des passages autorisés ; le chapitre 8 décrit les issues qui interrompent ce parcours : doublon, rejet, hors périmètre, sans objet, informatif.

Ce qui se déclenche sans intervention humaine

Trois automatismes tournent en arrière-plan. Ils expliquent la plupart des notifications reçues sans qu'un collègue ait touché au dossier.

Automatisme	Fréquence	Effet
Surveillance des échéances	Toutes les 30 minutes	Marque l'échéance proche à 80 % du délai, puis dépassée au terme. Notifie l'équipe du dossier et augmente son score de priorité de 10 points.
Veille des divulgations	Quotidienne	Alerte l'équipe sur les divulgations prévues dans les sept jours et non encore publiées.
Recalcul des priorités	Quotidienne	Réévalue le score 0-100 de chaque dossier ouvert : sévérité, secteur de l'organisation, ancienneté, dépassements d'échéance.

QUI EST QUI

3. Les acteurs et leurs droits

Dix rôles coexistent sur la plateforme. Ils se rangent en quatre familles dont les droits ne se recouvrent pas : personne ne cumule le dépôt d'un signalement et son arbitrage.

3.1 Les quatre familles

Famille	Rôles	Périmètre de visibilité	Second facteur
Déclarants	Utilisateur public, Chercheur en sécurité, Chercheur Bug Bounty	Uniquement leurs propres dossiers.	Non exigé
Équipe nationale	Agent de triage, Analyste CSIRT, Coordinateur national	Tous les dossiers de la plateforme.	Obligatoire
Organisation affectée	Administrateur DSI, Responsable d'organisation	Les dossiers de leurs organisations, et ceux où ils sont participants.	Obligatoire
Transverses	Auditeur (lecture seule), Administrateur système	Tous les dossiers ; l'auditeur n'écrit rien.	Obligatoire

Double authentification : la frontière est le rôle

Tout compte métier - triage, analyse, coordination, DSI, audit, administration - doit enrôler un authenticateur TOTP et valider un code à chaque session : tant que le second facteur n'est pas fourni, seules les pages d'enrôlement, de vérification et de déconnexion répondent. Les comptes déclarants en sont dispensés : leur exiger un authenticateur découragerait le signalement, qui est le but de la plateforme.

3.2 Ce que chaque rôle fait dans le processus

Rôle	Son rôle dans le traitement	Interventions
Agent de triage TRIAGER	Première ligne. Accuse réception, qualifie, décide de l'issue de triage. N'assigne pas et ne coordonne pas.	Étapes 1, 3, 4
Analyste CSIRT CSIRT_ANALYST	Conduit le dossier de bout en bout : qualification, assignation, contact de l'organisation, suivi de la correction, rédaction de l'advisory, proposition de récompense.	Étapes 1 à 8
Coordinateur national NATIONAL_COORDINATOR	Arbitre et signe. Seul, avec l'administrateur, à approuver une récompense, à publier un advisory et à lire les messages restreints.	Étapes 4, 7, 8, 9
Administrateur DSI DSI_ADMIN	Représente l'entité affectée : accuse réception du contact, pilote la correction, déclare le correctif disponible.	Étapes 5, 6
Responsable d'organisation ORGANIZATION_MANAGER	Même périmètre que la DSI, oriente gestion : membres, programmes, périmètres et propositions de récompense de son entité.	Étapes 5, 6
Auditeur AUDITOR	Lit tout, n'écrit rien : dossiers, journal d'audit, tableaux de bord, exports. Toute tentative d'écriture est refusée.	Contrôle à posteriori
Administrateur système SUPER_ADMIN	Détient toutes les capacités. Crée les comptes métiers, les organisations, les politiques de délai. N'intervient pas dans le traitement courant.	Paramétrage
Chercheur / Utilisateur public	Dépose un signalement, répond aux demandes d'information, vérifie le correctif si on le lui demande. Ne voit que ses dossiers.	Étapes 0, 3, 7

3.3 Qui peut faire quoi

Chaque action du traitement exige une capacité précise. Le tableau se lit colonne par colonne : un point signifie que le serveur accepte l'action pour ce rôle.

Action	Triage	Analyste	Coord.	DSI / Resp.	Auditeur
Voir tous les dossiers	•	•	•		•
Voir les dossiers de son organisation	•	•	•	•	•
Changer le statut d'un dossier	•	•	•	•	
Qualifier, valider, rejeter (triage)	•	•	•		
Définir la sévérité retenue	•	•	•		
Assigner un dossier		•	•		
Publier un message interne	•	•	•	•	
Proposer une récompense		•	•	•	
Approuver une récompense			•		
Enregistrer un versement			•		
Rédiger un advisory		•	•		
Publier un advisory			•		
Gérer un programme		•	•	•	
Consulter le journal d'audit			•		•
Exporter des données		•	•	•	•

Deux conséquences pratiques. Un **agent de triage** qualifie et décide, mais n'assigne pas un dossier à un collègue : la répartition de la charge reste à l'analyste ou au coordinateur. Une **DSI** fait avancer la correction mais ne valide ni ne rejette un signalement : la qualification reste nationale, pour qu'une entité ne puisse pas écarter ce qui la concerne.

PRÉPARATION

4. Avant le premier signalement

Un signalement n'arrive pas dans le vide : il vise une organisation référencée, souvent un programme publié, et il est traité selon une politique de délais. Ces trois objets sont créés par des utilisateurs métiers, avant tout dépôt.

4.1 Ce que le public voit et qui le prépare

Ce que le public trouve	Adresse	Prépare par
Politique de divulgation : engagement de l'État, règles de test, délais annoncés	/disclosure-policy/	Coordinateur national, administrateur
Fichier security.txt et clé PGP nationale, pour un signalement chiffré	/well-known/security.txt /pgp-key.asc	Administrateur
Annuaire des programmes VDP et Bug Bounty ouverts	/programs/	Analyste CSIRT, DSI, responsable d'organisation (capacité MANAGE_PROGRAM)
Annuaire des organisations participantes	/organizations/	Coordinateur national, responsable d'organisation
Advisories publiés et classement des chercheurs	/advisories/ /researchers/	Publiés à l'issue du processus (chapitre 8)

4.2 Créer une organisation

L'organisation porte le secteur, le statut et surtout ses **membres** : responsable, DSI, contact sécurité. Ce point est décisif pour la suite - ce sont ces trois profils que la plateforme rattache automatiquement à tout dossier concernant l'entité. Une organisation sans contact désigne recevra bien le dossier, mais personne ne le verra de son côté.

Qui	Où	Ce qu'il renseigne
Coordinateur national, administrateur (MANAGE_ALL_ORGANIZATIONS)	/organizations/manage/new/	Nom, sigle, type, secteur, statut, contact sécurité, acceptation du dispositif VDP.
Responsable d'organisation, DSI (MANAGE_ORGANIZATION)	/organizations/manage/	Met à jour sa propre fiche et ses membres : responsable, DSI, contact sécurité, analyste, observateur.

4.3 Créer un programme : VDP ou Bug Bounty

Le programme décide de deux choses qui pesent sur tout le traitement : **qui a le droit de signaler**, et **quel délai de divulgation** s'appliquera une fois le dossier validé.

	Programme VDP	Programme Bug Bounty
But	Recueillir les signalements sur un périmètre large.	Susciter la recherche sur un périmètre cible et délimité.
Signalement anonyme	Accepté par défaut.	Refuse : on ne récompense pas un chercheur qu'on ne peut pas identifier.
Compte et adresse vérifiée	Non exigés (réglage possible).	Exigés , sans exception possible.
Récompense	Aucune.	Matrice par sévérité, affiné par actif du périmètre.
Workflow	Divulgation coordonnée classique.	Idem, plus les étapes sévérité attribuée, revue et approbation de récompense.

Le programme porte aussi les **règles de test**, le **safe harbor** - l'engagement de ne pas poursuivre un chercheur qui respecte les règles -, le périmètre **inclus** et **exclu** actif par actif, la politique de délais applicable et le délai de divulgation (90 jours par défaut).

Le statut du programme conditionne la réception

Un programme n'accepte des signalements que s'il est **actif** et dans sa fenêtre de dates. Suspendu, clos ou encore en brouillon, il refuse le dépôt avec un message explicite - et l'annonce sur sa fiche publique, avant que le chercheur ait rédigé quoi que ce soit.

4.4 Fixer les délais

Une politique de délais rassemble les échéances appliquées aux dossiers. Un programme peut avoir la sienne ; sinon la politique par défaut s'applique. Valeurs livrées :

Échéance	Délai par défaut	Point de départ	Soldée par
Accusé de réception	72 heures	Dépôt du signalement	Passage en RECEIVED ou ACKNOWLEDGED
Premier triage	5 jours	Dépôt du signalement	Passage en TRIAGE ou toute décision de triage
Réponse de l'organisation	7 jours	Contact de l'organisation	Accusé de réception de l'organisation
Remédiation	30 j (critique et élevée) 60 j (moyenne) 90 j (faible)	Validation, ou entrée en remédiation	Correctif disponible ou vérifié
Divulgation	Date planifiée	Planification de la divulgation	Publication de l'advisory

Une alerte est levée dès 80 % du délai consommé. Le seuil, comme les délais, se modifie dans l'administration : rien n'est figé dans le code.

ÉTAPE 0

5. Le signalement : trois portes d'entrée

La plateforme accepte un signalement de trois façons, selon qui le dépose. Le formulaire est le même ; ce sont les conditions d'accès, le suivi offert et les suites possibles qui diffèrent.

	Citoyen sans compte	Chercheur inscrit	Chercheur Bug Bounty
Compte requis	Non	Oui	Oui, avec adresse vérifiée
Anonymat	Possible, total ou avec adresse de contact	Possible au titre du crédit public	Impossible
Programmes accessibles	VDP acceptant l'anonymat	Tous les programmes VDP	Bug Bounty, plus les VDP
Suivi du dossier	Par courriel, si une adresse a été laissée	Espace personnel, messagerie, notifications	Idem, plus le suivi de la récompense
Réputation	Non	Oui, à la validation	Oui, plus les montants perçus
Récompense	Non	Non	Oui, selon la matrice du programme

5.1 Le citoyen sans compte

Un agent public, un usager, un informaticien de passage remarque une anomalie et veut la signaler sans créer de compte. Il ouvre **/report/** depuis le bandeau Signaler.

- Il décrit la vulnérabilité : titre, organisation affectée ou programme, produit, adresse concernée, description (30 caractères au minimum), étapes de reproduction, impact, recommandations. Le Markdown est accepté.
- Il indique une **adresse de contact**, ou coche **signalement anonyme**. L'un des deux est obligatoire : sans rien, le formulaire refuse.
- Il peut joindre jusqu'à cinq fichiers, et coller un **bloc PGP chiffré** si le contenu est trop sensible pour être stocké en clair.
- Il accepte la politique de divulgation : la case est obligatoire et son acceptation est conservée avec le rapport.

À l'envoi, il obtient une page de confirmation portant la **référence EVDP-AAAA-NNNNNN**, à conserver, et l'annonce du délai de 72 heures. La page lui propose de créer un compte pour suivre le dossier.

Anonymat total : le silence est le prix

Sans compte et sans adresse de contact, la plateforme n'a aucun moyen de joindre le déclarant : il ne recevra ni accusé de réception, ni demande d'information, ni avis de publication. C'est un choix légitime, mais il faut le connaître. Une adresse de contact, même jetable, suffit à ouvrir le canal de retour sans rien révéler de l'identité.

5.2 Le chercheur en sécurité inscrit

Le chercheur crée son compte sur **/register/**, choisit son **mode d'identité** - nom public, pseudonyme, ou anonyme - et reçoit un courriel de vérification. Ce mode d'identité est celui qui sera repris dans le crédit public de l'advisory, des mois plus tard.

- Il dépose depuis le même formulaire, sans avoir à saisir d'adresse de contact : son compte fait foi.
- À l'envoi, il est conduit directement sur le **dossier**, ou il verra l'état, la chronologie, les échéances et la messagerie.
- Il reçoit une notification interne et un courriel à chaque évolution : accusé de réception, demande d'information, validation, rejet, publication.
- Il peut demander l'attribution d'un **CVE** et déclarer s'il souhaite être **crédité publiquement**.

- La validation de son rapport lui attribue des **points de réputation**, majorés pour une sévérité élevée ou critique. Ces points ne sont jamais modifiables à la main par le chercheur.

5.3 Le chercheur Bug Bounty

Le chercheur Bug Bounty part du programme, pas du formulaire : il lit la fiche publique sur **/programs/**, le périmètre inclus et exclu, les règles de test, le safe harbor et la grille de récompense, puis dépose depuis la fiche - le programme est alors pré-sélectionné.

Condition	Pourquoi	Ce qui se passe si elle manque
Être connecté avec un compte	Une récompense se verse à une personne identifiée.	Le dépôt est refusé, avec l'invitation à se connecter. Le message apparaît dès l'ouverture du formulaire , pas après rédaction.
Adresse email vérifiée	Personne ne doit pouvoir encaisser au nom d'une adresse qu'il ne contrôle pas.	Le dépôt est refusé et renvoie vers le profil, ou la vérification se relance en un clic.
Programme ouvert	Une campagne à des dates.	Le dépôt est refusé : programme suspendu, clos ou hors période.
Cible dans le périmètre	Le hors-périmètre est annoncé à l'avance.	Le dépôt est accepté, mais le triage conclura hors périmètre et le dossier sera clos sans récompense.

Les comptes créés avant l'entrée en vigueur de l'exigence de vérification bénéficient d'un **sursis** : ils participent encore pendant un délai défini, sont relancés par courriel, et le CSIRT dispose d'un export de ceux dont le sursis expire - une adresse jamais vérifiée peut être une adresse morte, que la relance automatique ne touchera jamais.

5.4 Les deux autres canaux

Canal	Pour qui	Particularité
API v1 /api/v1/reports/	Outillage d'un chercheur, intégration d'un CERT partenaire	Même service de soumission que le formulaire : mêmes contrôles, même ouverture de dossier, mêmes notifications.
Import CSAF /api/v1/import/csaf/	Équipe nationale (capacité IMPORT_CSAF)	Reprise d'un avis de sécurité au format normalisé, transmis par un éditeur ou un CERT étranger.

5.5 Ce que la plateforme fait à la seconde du dépôt

Le dépôt n'est pas un simple enregistrement : neuf opérations s'enchaînent dans une seule transaction. Les connaître évite de chercher à la main ce qui est déjà fait.

	Opération	Conséquence pour le traitement
1	Le rapport est enregistré, privé , avec l'empreinte de l'adresse IP du dépôt - jamais l'adresse elle-même.	La matière brute est figée : elle ne sera plus modifiée par personne.
2	Un dossier EVDP-AAAA-NNNNNN est ouvert au statut SUBMITTED.	C'est lui que l'équipe traite ; la référence sert dans tous les échanges.
3	Le workflow est choisi : Bug Bounty si le programme en est un, divulgation coordonnée sinon.	Il détermine les états atteignables pour toute la vie du dossier.
4	La sévérité initiale est calculée depuis le vecteur CVSS fourni, ou reprise de l'estimation du déclarant.	Elle sera revue au triage ; elle sert entre-temps au classement.
5	La chronologie s'ouvre sur Rapport reçu .	Premier jalon, public : il figurera dans l'advisory.

	Opération	Conséquence pour le traitement
6	Les participants sont rattachés : le déclarant, puis le responsable, la DSI et le contact sécurité de l'organisation visée.	Ce sont eux qui recevront les notifications et verront le dossier.
7	Les échéances 72 heures et 5 jours sont armées.	Le compte à rebours commence, même la nuit et le week-end.
8	Le score de priorité est calculé.	Il classe le dossier dans la file de traitement.
9	Notifications : l' équipe de triage est prévenue, le déclarant reçoit son accusé de dépôt ; le dépôt est journalisé.	Personne n'a besoin de surveiller une boîte aux lettres.

DU DOSSIER REÇU AU CORRECTIF VÉRIFIÉ

6. Le traitement, étape par étape

Chaque étape est présentée de la même façon : qui agit, quand, depuis quel écran, avec quelle autorisation, et ce que l'action produit. Les étapes 1 à 4 se déroulent au CSIRT, les étapes 5 à 7 avec l'organisation affectée, les étapes 8 et 9 avec la coordination nationale.

1

Prise en charge et accusé de réception

Qui	Agent de triage, analyste CSIRT, coordinateur national
Quand	Dans les 72 heures suivant le dépôt
Où	/cases/ (file triée par priorité) ou /cases/kanban/, colonne Soumis
Autorisation	CHANGE_CASE_STATUS
Transition	SUBMITTED → RECEIVED → ACKNOWLEDGED

Le dossier arrive dans la colonne **Soumis** du tableau Kanban et en tête de la file si sa sévérité annoncée est haute. L'agent l'ouvre, lit le rapport, vérifie qu'il est exploitable - une description vide de sens, un doublon évident, un contenu hors sujet se voient dès la première lecture - puis le passe en **Reçu**, et **Accusé de réception** une fois le déclarant informé.

Ce que l'action déclenche	Détail
L'échéance de 72 heures est soldée	Elle disparaît des échéances à risque ; le dossier cesse d'alimenter les alertes de retard sur ce point.
Le déclarant est notifié	Notification interne et courriel s'il a un compte ; courriel seul s'il a laissé une adresse ; rien s'il est totalement anonyme.
La chronologie est complétée	Jalon Accusé de réception , public : il figurera dans l'advisory final.
L'historique retient l'auteur	Ancien statut, nouveau statut, auteur, horodatage, commentaire éventuel.

Accuser réception n'est pas valider

L'accusé de réception dit seulement : nous avons lu, nous traitons. Il n'engage sur aucune qualification. Le déclarant est informé par un message neutre ; c'est au triage, ensuite, de dire si la vulnérabilité est retenue.

2

Assignment à un analyste

Qui	Analyste CSIRT, coordinateur national
Quand	Dès la prise en charge, avant le travail de qualification
Où	Fiche du dossier, bloc Assignment
Autorisation	ASSIGN_CASE
Transition	Aucune : le statut ne change pas

L'assignment désigne le responsable du dossier. Elle n'est pas obligatoire pour avancer, mais un dossier sans titulaire est un dossier que personne ne surveille : c'est le premier réflexe d'organisation de la file.

- L'analyste désigné devient **participatif** du dossier et reçoit une notification d'assignment.
- Toute assignment antérieure est désactivée : un seul titulaire à la fois, et l'historique conserve la suite des passations.

- L'**agent de triage** ne dispose pas de cette capacité : il qualifie, mais ne répartit pas la charge de l'équipe.

3 Qualification technique

Qui	Agent de triage, analyste CSIRT, coordinateur national
Quand	Dans les 5 jours suivant le dépôt
Où	Fiche du dossier, bloc Qualification
Autorisation	TRIAGE_CASE, et SET_SEVERITY pour la sévérité
Transition	vers TRIAGE, puis vers la décision de l'étape 4

La qualification est le travail d'expertise du CSIRT : elle transforme une déclaration en dossier exploitable. Six champs sont à renseigner.

Champ	Ce qu'il engage pour la suite
Sévérité retenue	Elle commande le délai de correction (30, 60 ou 90 jours), le score de priorité, le palier de récompense et les points de réputation du chercheur. C'est la décision la plus lourde de l'étape.
Vecteur CVSS v3.1	S'il est fourni, le score est recalculé par la plateforme et la sévérité peut en découler. Un vecteur mal formé est refusé à la saisie.
CWE	Classe la faiblesse ; alimente les statistiques nationales et l'advisory.
Organisation affectée	Souvent absente ou approximative dans le rapport. La corriger ici ouvre le dossier aux contacts de l'entité : c'est ce qui rend la coordination possible.
Actif du périmètre	Sur un programme, désigne la cible concernée. Détermine la grille de récompense quand elle varie par actif.
Étiquettes	Douze au maximum. Servent au filtrage et aux regroupements par campagne ou par technologie.

Si le rapport est incomplet, le dossier passe en **Informations demandées** : le déclarant reçoit une notification dédiée et répond par la messagerie du dossier. L'échéance de triage, elle, continue de courir - le chapitre 9 explique comment le suivre.

4 La décision de triage

Qui	Agent de triage, analyste CSIRT, coordinateur national
Quand	À l'issue de la qualification, dans les 5 jours
Où	Fiche du dossier, bloc Changer le statut
Autorisation	TRIAGE_CASE
Transition	TRIAGE → VALIDATED, ou une issue de triage

C'est le point de bascule du dossier : soit la vulnérabilité est retenue et le processus de correction s'engage, soit le dossier prend une issue qui le referme. Six sorties sont possibles.

Décision	Quand la retenir	Suite
Valide	La vulnérabilité est réelle, reproductible, dans le périmètre.	Le traitement continue à l'étape 5.
Doublon	Le même défaut est déjà suivi dans un autre dossier.	Dossier clos. Le déclarant est informé du doublon, sans jamais connaître le dossier d'origine .

Décision	Quand la retenir	Suite
Rejeté	Le défaut n'est pas démontré, ou le rapport n'est pas exploitable.	Dossier clos, notification au déclarant.
Hors périmètre	La cible ne figure pas dans le périmètre du programme.	Dossier clos ; aucune récompense possible.
Non applicable	Comportement conforme, protection déjà en place, risque inexistant.	Dossier clos.
Informatif	Constat utile, sans vulnérabilité exploitable.	Le dossier reste ouvert puis est clos ; il alimente les statistiques.

Ce que la validation déclenche

Effet	Détail
Date de validation posée	Elle sert de référence à tous les délais qui suivent.
Date de divulgation calculée	Validation plus le délai du programme, 90 jours par défaut. Elle est modifiable ensuite, mais elle existe dès maintenant : l'organisation sait de combien de temps elle dispose.
Échéance de correction armée	30 jours (critique, élevée), 60 (moyenne) ou 90 (faible), selon la sévérité retenue à l'étape 3.
Réputation attribuée	Points de base au chercheur, majorés pour une sévérité élevée ou critique. L'attribution n'a lieu qu'une fois par dossier.
Déclarant notifié	Message de validation, distinct de l'accusé de réception.

Sur un programme Bug Bounty, la suite diffère

Après la validation, le dossier ne part pas directement en coordination : il passe par **Sévérité attribuée**, puis par la **revue de récompense** et l'**approbation**. Ces trois états n'existent pas dans le workflow de divulgation coordonnée - la machine à états les refuse. Voir le chapitre 7.

5 Coordination avec l'organisation affectée

Qui	Analyste CSIRT ou coordinateur national ; réponse de la DSI
Quand	Dès la validation. L'organisation répond sous 7 jours
Où	Fiche du dossier : statut, puis messagerie sécurisée
Autorisation	CHANGE_CASE_STATUS
Transition	VALIDATED → VENDOR_CONTACTED → VENDOR_ACKNOWLEDGED

L'organisation affectée entre ici dans le dossier. Elle y a accès parce que ses contacts en sont participants depuis l'ouverture, ou parce que le triage lui a rattaché le dossier à l'étape 3.

Côté CSIRT

- Passer le dossier en **Organisation contactée** : l'échéance de réponse de 7 jours s'arme aussitôt.
- Écrire le premier message au niveau **Participants** : c'est le seul niveau que la DSI et le déclarant lisent.
- Préciser ce qui est attendu : accusé de réception, interlocuteur technique, délai de correction envisagé.

Côté organisation

- L'administrateur DSI ou le responsable d'organisation ouvre le dossier depuis **/dashboard/organization/**, qui ne montre que les vulnérabilités de son entité.
- Il répond par la messagerie, puis passe le dossier en **Organisation a accusé réception** : l'échéance de 7 jours est soldée.

- Il peut déposer des pièces jointes - plan de correction, captures, note technique.

Le choix du niveau de message est un acte de confidentialité

Trois niveaux coexistent sur la même page. **Participants** est lu par le déclarant et par l'organisation. **Interne CSIRT** ne sort pas de l'équipe nationale. **Restreint** n'est lu que par la coordination nationale. Le niveau se choisit avant d'envoyer, et il ne se corrige pas après.

6 Remédiation

Qui	Administrateur DSI, responsable d'organisation, avec l'analyste
Quand	30 jours (critique, élevée), 60 (moyenne), 90 (faible) après la validation
Où	Fiche du dossier, bloc Changer le statut et messagerie
Autorisation	CHANGE_CASE_STATUS
Transition	REMIEDIATION → FIX_AVAILABLE

L'entité corrige. La plateforme ne fait pas le travail à sa place : elle tient le délai, garde la trace des échanges et prévient quand l'échéance approche.

- L'organisation tient le dossier à jour par la messagerie : diagnostic, contournement provisoire, date de mise en production.
- Une alerte part à **80 %** du délai consommé, une seconde au dépassement. Le dépassement ajoute 10 points au score de priorité : le dossier remonte dans la file de tout le monde.
- Quand le correctif est en place, le dossier passe en **Correctif disponible**. L'échéance de correction est alors soldée.

Un délai intenable se négocie **dans le dossier**, par un message argumenté, et non par l'oubli de l'échéance : le coordinateur peut repousser la date de divulgation (étape 8), ce qui laisse une trace datée de la décision et de son motif.

7 Vérification du correctif

Qui	Analyste CSIRT ; le chercheur est associé à la contre-vérification
Quand	Dès l'annonce du correctif
Où	Fiche du dossier
Autorisation	CHANGE_CASE_STATUS
Transition	FIX_AVAILABLE → VERIFICATION → FIX_VERIFIED, ou retour en REMEDIATION

La vérification est ce qui distingue un dossier clos d'un dossier résolu. Le déclarant d'origine est le mieux placé pour dire si le contournement tient : l'analyste lui demande son avis par la messagerie, au niveau Participants.

- Si le correctif tient : **Correctif vérifié**. La date de remédiation est posée et le dossier est prêt pour la divulgation.
- Si le correctif ne tient pas : retour en **Remédiation en cours**. La machine à états autorise explicitement ce retour arrière - c'est le seul du parcours nominal.
- Un dossier qui n'appelle aucune publication peut être **clos** directement depuis cet état.

6.1 Table des passages autorisés

La machine à états n'accepte que les passages listés ci-dessous. Tout autre essai est refusé avec un message explicite, et le refus est inscrit au journal d'audit - y compris lorsqu'il vient d'une adresse forgée à la main.

Depuis	Vers (divulgaration coordonnée)	Vers (Bug Bounty)
SUBMITTED	RECEIVED, TRIAGE	RECEIVED, TRIAGE
RECEIVED	ACKNOWLEDGED, TRIAGE	ACKNOWLEDGED, TRIAGE
ACKNOWLEDGED	TRIAGE	TRIAGE
TRIAGE	NEEDS_INFORMATION, VALIDATED, et les cinq issues de triage	Idem
NEEDS_INFORMATION	TRIAGE, et les cinq issues de triage	Idem
VALIDATED	IN_PROGRESS, VENDOR_CONTACTED, NEEDS_INFORMATION, DUPLICATE	SEVERITY_ASSIGNED , NEEDS_INFORMATION, DUPLICATE
SEVERITY_ASSIGNED	-	BOUNTY_REVIEW, REMEDIATION
BOUNTY_REVIEW	-	REWARD_APPROVED, REMEDIATION
REWARD_APPROVED	-	REMEDIATION
IN_PROGRESS	VENDOR_CONTACTED, REMEDIATION	-
VENDOR_CONTACTED	VENDOR_ACKNOWLEDGED, REMEDIATION, DISCLOSURE_SCHEDULED	-
VENDOR_ACKNOWLEDGED	REMEDIATION	-
REMEDIATION	FIX_AVAILABLE, DISCLOSURE_SCHEDULED	FIX_AVAILABLE, VERIFICATION
FIX_AVAILABLE	VERIFICATION	VERIFICATION
VERIFICATION	FIX_VERIFIED, REMEDIATION	FIX_VERIFIED, REMEDIATION
FIX_VERIFIED	DISCLOSURE_SCHEDULED, CLOSED	Idem
DISCLOSURE_SCHEDULED	PUBLISHED, CLOSED	Idem
PUBLISHED	CLOSED	CLOSED
INFORMATIVE	CLOSED	CLOSED
CLOSED, REJECTED, DUPLICATE, OUT_OF_SCOPE, NOT_APPLICABLE	<i>Aucune : états terminaux</i>	<i>Aucune</i>

Les cinq issues de triage sont : DUPLICATE, REJECTED, OUT_OF_SCOPE, NOT_APPLICABLE et INFORMATIVE. Quatre d'entre elles sont terminales ; INFORMATIVE conduit à la clôture.

ÉTAPES 4 BIS

7. La branche Bug Bounty : la récompense

Sur un programme Bug Bounty, la validation ouvre une séquence supplémentaire avant la correction : attribuer la sévérité définitive, proposer un montant, le faire approuver, puis enregistrer le versement. Cette séquence obéit à une règle de séparation stricte : **celui qui propose n'approuve pas**.

VALIDATED

SEVERITY_ASSIGNED

BOUNTY_REVIEW

REWARD_APPROVED

REMEDiation

7.1 Qui fait quoi

Acte	Qui en a le droit	Autorisation	Effet
Proposer un montant	Analyste CSIRT, coordinateur national, DSI, responsable d'organisation	PROPOSE_BOUNTY	Crée la récompense au statut Proposée et notifie le chercheur.
Donner un avis	Mêmes profils	PROPOSE_BOUNTY	Avis favorable, défavorable, ajustement ou commentaire. Fait passer la récompense en En revue .
Approuver ou rejeter	Coordinateur national, administrateur uniquement	APPROVE_BOUNTY	Fixe le montant définitif, date et signe la décision, notifie le chercheur.
Enregistrer le versement	Coordinateur national, administrateur	RECORD_PAYMENT	Trace comptable du paiement effectué hors plateforme ; la récompense passe à Payée .

Un analyste ne peut pas approuver ce qu'il a proposé

La capacité d'approbation n'est accordée ni à l'analyste CSIRT, ni à la DSI, ni au responsable d'organisation. Le refus est prononcé par le serveur, pas par l'interface : il tient même si la requête est forgée. La décision financière reste ainsi séparée de l'expertise technique qui la motive.

7.2 D'où vient le montant proposé

Le montant n'est jamais inventé : il vient de la **matrice du programme**, qui associe à chaque sévérité un palier minimum et maximum. Un actif du périmètre peut avoir son propre palier - une faille critique sur une API de production ne vaut pas la même chose que sur un site vitrine. C'est l'actif retenu au triage (étape 3) qui sélectionne la grille ; à défaut, celle du programme s'applique. La plateforme propose par défaut la borne haute du palier ; l'analyste peut la réduire.

Situation	Ce que fait la plateforme
Montant dans le palier de la sévérité	Approbation ordinaire.
Montant hors palier	L'approbation reste possible - les situations exceptionnelles existent - mais elle est signalée à l'écran et journalisée avec un avertissement explicite.
Chercheur sans adresse vérifiée	La proposition est refusée . Le contrôle est refait ici, après celui du dépôt : le programme a pu devenir plus exigeant entre-temps.
Dossier sans chercheur identifié	La proposition est refusée : aucune récompense sans destinataire.
Programme sans matrice active	Montant suggéré nul ; le montant doit être saisi et justifié à la main.

7.3 Cycle de vie de la récompense

PROPOSÉE

EN REVUE

APPROUVÉE

PAYÉE

Depuis **Proposée** ou **En revue**, la récompense peut aussi être **rejetée** ou **annulée** ; ces deux états sont définitifs, comme **Payée**. Une récompense déjà tranchée ne peut plus être reproposée.

7.4 Le paiement

La plateforme **n'exécute aucun flux financier**. Le versement est réalisé hors plateforme par le service financier - virement bancaire, mobile money - puis enregistre ici : montant, devise, moyen, référence externe, agent ayant saisi, date. Cette trace est ce qui permet le rapprochement comptable, et c'est elle qui fait passer la récompense à **Payée**.

Le chercheur suit l'ensemble depuis son espace : montant proposé, décision, versement, et cumul perçu. Chaque changement lui vaut une notification.

La récompense ne remplace pas la correction

Une récompense approuvée n'arrête pas le dossier : il repart en **Remédiation**, puis suit le même chemin qu'un dossier de divulgation coordonnée jusqu'à la vérification, la publication éventuelle et la clôture. Payer n'est pas corriger.

ÉTAPES 8 ET 9

8. Divulgement, publication et clôture

8

Planifier la divulgation et rédiger l'advisory

Qui	Analyste CSIRT rédige ; coordinateur national publie
Quand	Après vérification du correctif, à la date planifiée
Où	Fiche du dossier (date, CVE) ; /advisories/manage/ pour la rédaction
Autorisation	CHANGE_CASE_STATUS, DRAFT_ADVISORY, PUBLISH_ADVISORY
Transition	FIX_VERIFIED → DISCLOSURE_SCHEDULED → PUBLISHED

La divulgation est le seul moment où une information sort du cercle des participants. Elle se prépare en quatre temps.

	Acte	Qui	Détail
1	Fixer la date	Analyste, coordinateur	Une date pré-calculée existe depuis la validation. La confirmer ou la déplacer arme l'échéance de divulgation et inscrit le jalon dans la chronologie.
2	Associer un CVE	Analyste, coordinateur	Si un identifiant a été obtenu, il est rattaché au dossier et reporté dans l'advisory.
3	Rédiger l'advisory	Analyste CSIRT	Depuis le dossier, l'action Rédiger un advisory prépare un brouillon assaini : titre, produit, sévérité, CVSS, CWE, CVE, crédit du chercheur et chronologie publique. Ni preuve de concept, ni étapes de reproduction, ni URL cible ne sont repris.
4	Relire puis publier	Analyste puis coordinateur	Brouillon, puis En relecture, puis Approuvé. La publication elle-même est réservée au coordinateur national.

Le cycle de l'advisory

BROUILLON

EN RELECTURE

APPROUVÉ

PLANIFIÉ

PUBLIÉ

Un advisory publié peut être **retiré**, avec motif obligatoire ; le retrait est journalisé. Un résumé public vide interdit la publication.

Contrôle avant publication

- Aucune preuve de concept, aucune étape de reproduction exploitable.
- Aucune URL interne, aucun identifiant de dossier.
- Le correctif est effectivement disponible et vérifié.
- L'organisation affectée connaît la date et l'a acceptée.
- Le **crédit** respecte le choix du chercheur : nom public, pseudonyme, ou **Chercheur anonyme** s'il à demande l'anonymat ou refuse le crédit.
- La sévérité, le CVSS et le CWE publiés correspondent à ceux retenus au triage.

À la publication, le dossier passe en **Publié**, la chronologie s'enrichit du jalon correspondant et le chercheur est notifié avec le lien vers l'advisory. La chronologie publique ne reprend que les jalons marqués publics : rapport reçu, accusé de réception, validation, organisation contactée, correctif fourni, correctif vérifié, advisory publié.

9

Clôture du dossier

Qui	Analyste CSIRT, coordinateur national
Quand	Après publication, ou dès la vérification si rien n'est publié
Où	Fiche du dossier, bloc Changer le statut
Autorisation	CHANGE_CASE_STATUS
Transition	PUBLISHED, FIX_VERIFIED ou DISCLOSURE_SCHEDULED → CLOSED

La clôture solde le dossier. Elle produit quatre effets.

- La date de clôture est posée et le dossier quitte les files de travail.
- **Toutes les échéances encore en cours sont annulées** : le dossier cesse d'alimenter les alertes de retard.
- Le jalon de clôture rejoint la chronologie, et l'historique conserve qui a clos, quand et pourquoi.
- L'état est **terminal** : aucune transition ne part d'un dossier clos. Une reprise suppose un nouveau dossier, rattaché au précédent.

Tout n'a pas vocation à être publié

Un dossier peut être clos sans advisory : correctif vérifié sans intérêt public, infrastructure trop sensible pour être décrite, demande motivée de l'organisation. La décision appartient à la coordination nationale et se prend dossier par dossier - elle laisse une trace, comme le reste.

CE QUI SORT DU RAIL

9. Cas particuliers et issues alternatives

9.1 Le déclarant ne répond plus

Un dossier en **Informations demandées** attend une réponse qui ne vient pas toujours. L'échéance de triage continue de courir et le dossier remonte dans la file à mesure qu'il vieillit. Deux issues : relancer par la messagerie, ou trancher sur les seuls éléments disponibles - le plus souvent **Rejeté**, faute de démonstration. Dans les deux cas, le motif est écrit dans le commentaire de transition : c'est lui que relira le collègue qui reprendra le dossier.

9.2 Doubleton : ce que le déclarant apprend, et ce qu'il n'apprend pas

Marquer un doubleton rattache le dossier à l'original et le clôt. Le déclarant est informé que son rapport est un doubleton - **rien de plus**. Ni la référence du dossier d'origine, ni son contenu, ni l'organisation concernée ne lui sont révélés : ce serait lui apprendre l'existence d'une vulnérabilité non corrigée qu'il n'a pas découverte. Seule la coordination nationale voit le lien entre les deux dossiers.

9.3 Rapport chiffré PGP

Un déclarant peut coller un bloc PGP chiffré à la place du contenu sensible. La plateforme vérifie qu'il s'agit bien d'un message chiffré, le stocke tel quel et signale le dossier comme chiffré. **Aucune clé privée n'est détenue par la plateforme** : le déchiffrement se fait hors ligne, par l'équipe destinataire, avec sa propre clé. Le traitement suit son cours normalement pour tout le reste.

9.4 Le déclarant est anonyme et injoignable

Le dossier vit sa vie complète - triage, correction, publication - mais aucune notification ne part. En pratique : pas de demande d'information possible, donc un rapport incomplet finira rejeté ; pas de contre-vérification du correctif par le déclarant ; crédit public mentionné comme anonyme. C'est le coût de l'anonymat total, et il est assumé.

9.5 Pièces jointes refusées

Les pièces jointes sont contrôlées à trois niveaux : taille, extension, et **signature binaire** du contenu. Un exécutable renommé en .png est refusé - c'est sa signature qui le trahit, pas son nom. Chaque fichier accepté reçoit une empreinte SHA-256, et chaque téléchargement est journalisé : ces fichiers sont des preuves de vulnérabilités non corrigées.

9.6 Un signalement qui ne vise aucune organisation référencée

Le déclarant peut nommer librement une entité absente de l'annuaire. Le dossier reste alors visible de la seule équipe nationale : personne, côté organisation, ne peut y accéder. C'est au triage de rattacher le dossier à l'organisation réelle - ou de la faire créer - faute de quoi la coordination de l'étape 5 n'a pas d'interlocuteur.

9.7 Reprendre un dossier clos

Les états **Clos**, **Rejeté**, **Doubleton**, **Hors périmètre** et **Non applicable** sont terminaux : la machine à états n'en laisse sortir aucune transition. Si un élément nouveau apparaît - un rejet erroné, une régression du correctif - la marche à suivre est d'ouvrir un nouveau dossier et d'y citer l'ancien. L'historique du premier reste intact, ce qui est précisément l'intérêt de ne pas le rouvrir.

TENIR LA CHARGE

10. Délais, priorités et écrans de pilotage

10.1 Les cinq échéances et leur cycle

Chaque échéance passe par les mêmes états : **En cours**, puis **Échéance proche** à 80 % du délai, puis **Respectée** si l'action attendue survient, **Dépassée** sinon. La clôture ou la publication **annule** les échéances restantes.

Échéance	Armée par	Soldée par	Qui doit agir
Accusé de réception 72 h	Le dépôt du signalement	Passage en Reçu ou Accusé de réception	Agent de triage, analyste
Premier triage 5 jours	Le dépôt du signalement	Entrée en triage ou décision de triage	Agent de triage, analyste
Réponse de l'organisation 7 jours	Le contact de l'organisation	Accusé de réception de l'organisation	DSI, responsable d'organisation
Remédiation 30 / 60 / 90 jours	La validation, ou l'entrée en remédiation	Correctif disponible ou vérifié	DSI, responsable d'organisation
Divulgence date fixée	La planification de la divulgation	La publication de l'advisory	Analyste, coordinateur national

10.2 Le score de priorité

Chaque dossier ouvert porte un score de 0 à 100 qui ordonne la file de travail. Il se recalcule à chaque changement d'état et, chaque nuit, pour tous les dossiers ouverts.

Composante	Apport au score
Sévérité retenue	Critique 80, Élevée 60, Moyenne 35, Faible 15, Informatrice 5
Secteur de l'organisation	+5 pour la défense et le gouvernement
Ancienneté	+1 par semaine écoulée, plafonné à +10
Échéance dépassée	+10 dès le premier dépassement

Un dossier moyen qui traîne finit donc par dépasser un dossier élevé tout juste arrivé : c'est voulu. L'ancienneté et le retard sont des risques, au même titre que la sévérité.

10.3 Où travailler, selon le rôle

Écran	Adresse	Pour qui	Usage
File des dossiers	/cases/	Équipe nationale, organisation	Liste filtrable par statut, sévérité, organisation, texte. Triée par priorité.
Tableau Kanban	/cases/kanban/	Équipe nationale, organisation	Les sept colonnes du workflow : Soumis, Triage, Valide, Remédiation, Vérification, Divulgence, Clos. Vue de charge.
Fiche d'un dossier	/cases/EVDP-.../	Participants du dossier	Rapport, messagerie, pièces jointes, chronologie, échéances, participants, et les actions autorisées par le rôle.
Tableau de bord CSIRT	/dashboard/csirt/	Triage, analyste, coordinateur, auditeur	Volumes, répartition par sévérité, par secteur, par type, top CWE, dossiers en retard, délai moyen de correction.

Écran	Adresse	Pour qui	Usage
Tableau de bord national	/dashboard/national/	Coordinateur, auditeur	Posture agrégée : aucune information identifiant une infrastructure sensible.
Espace organisation	/dashboard/organization/	DSI, responsable d'organisation	Les seules vulnérabilités de l'entité, ses retards, ses programmes, ses advisories.
Espace chercheur	/dashboard/researcher/	Déclarants inscrits	Ses dossiers, ses récompenses, sa réputation, les programmes ouverts.
Recherche globale	/dashboard/search/	Équipe nationale, organisation	Recherche transverse dans le périmètre visible.
Récompenses	/bounties/	Selon le périmètre visible	Suivi des propositions, revues, approbations et versements.
Rédaction d'advisories	/advisories/manage/	Analyste, coordinateur	Brouillons, relectures, publications, retraits.
Journal d'audit	/audit/	Coordinateur, auditeur	Toutes les actions, y compris les refus.

Le menu latéral se déduit du rôle : il n'affiche que ce que le compte peut réellement ouvrir. Un menu qui annoncerait une page interdite apprendrait au lecteur à se méfier de ce qu'il lit.

10.4 Exports

Les exports reprennent exactement le périmètre visible de celui qui les demande, et sont journalisés : **CSV** et **Excel** de la liste des dossiers, **PDF** d'un dossier complet, **CSV** des comptes non vérifiés sur le point de perdre l'accès aux programmes Bug Bounty. Capacité requise : EXPORT_DATA.

MESSAGERIE, AVIS, FICHIERS

11. Échanger sur un dossier

11.1 Les trois niveaux de confidentialité

Tous les messages d'un dossier s'écrivent au même endroit. Ce qui change, c'est le niveau choisi avant l'envoi - et donc qui lira.

Niveau	Lu par	Usage	Qui peut l'employer
Participants	Déclarant, organisation affectée, équipe nationale	Tout ce qui s'adresse au déclarant ou à l'entité : demande d'information, contact initial, suivi de correction, vérification.	Tous les participants
Interne CSIRT	Équipe nationale uniquement	Analyse entre collègues, hypothèses, coordination interne.	Capacité POST_INTERNAL_MESSAGE
Restreint	Coordination nationale uniquement	Éléments sensibles : liens entre dossiers, contexte politique, arbitrages.	Coordinateur national, administrateur

Le déclarant lit les messages Participants

C'est l'erreur la plus courante et la plus coûteuse : une analyse interne postée au niveau Participants est lue par le déclarant et par l'organisation, et rien ne permet de la reprendre. Le niveau se vérifie avant l'envoi. Un chercheur ou une DSI, eux, n'ont accès qu'au niveau Participants : ils ne peuvent pas se tromper.

11.2 Qui est prévenu, et quand

Événement	Destinataire	Canal
Nouveau signalement	Agents de triage, analystes CSIRT, coordinateurs	Notification interne et courriel
Accusé de réception, validation, rejet, doublon, demande d'information	Le déclarant	Notification et courriel s'il a un compte ; courriel seul s'il a laissé une adresse
Tout autre changement de statut	Le déclarant et l'équipe du dossier, sauf l'auteur de l'action	Notification et courriel
Nouveau message, nouvelle pièce jointe	Les participants du dossier, sauf l'auteur	Notification et courriel
Assignment	L'analyste désigné	Notification et courriel
Échéance proche, échéance dépassée	L'équipe du dossier	Notification et courriel
Divulgence prévue sous 7 jours	L'équipe du dossier	Notification et courriel
Récompense proposée, approuvée, rejetée, payée	Le chercheur	Notification et courriel
Advisory publié	Le chercheur, avec le lien public	Notification et courriel

11.3 Pièces jointes

- Cinq fichiers au maximum à la soumission ; d'autres peuvent être ajoutés ensuite depuis la fiche du dossier.
- Extensions autorisées limitées, extensions dangereuses interdites, taille plafonnée, **signature binaire vérifiée** : un exécutable déguisé est refusé.
- Chaque fichier porte une empreinte SHA-256, son auteur et sa date ; chaque téléchargement est journalisé.
- Ces fichiers contiennent des preuves de vulnérabilités **non corrigées** : ils ne sortent pas de la plateforme, et les sauvegardes qui les contiennent sont chiffrées.

VUE CÔTÉ SIGNALANT

12. Ce que voit le déclarant

Un traitement rigoureux côté CSIRT ne vaut que si le déclarant comprend où en est son signalement. Voici exactement ce qui lui parvient, selon son profil, à chaque étape.

Étape	Citoyen anonyme	Citoyen avec adresse	Chercheur inscrit / Bug Bounty
Dépôt	Référence affichée à l'écran	Référence affichée, plus un courriel	Référence, redirection vers le dossier, notification
Accusé de réception	Rien	Courriel	Notification, courriel, statut visible
Demande d'information	Impossible	Courriel, sans possibilité de répondre dans le dossier	Notification, et réponse par la messagerie
Validation ou rejet	Rien	Courriel	Notification, motif visible, points de réputation
Correction en cours	Rien	Courriel à chaque changement de statut	Chronologie, échéances et messages en direct
Vérification	Impossible	Non sollicité	Sollicité par message pour confirmer le correctif
Publication	Advisory public, crédit anonyme	Courriel, crédit selon son choix	Notification avec le lien, crédit selon son mode d'identité
Récompense	Sans objet	Sans objet	Bug Bounty : suivi du montant proposé, approuvé, versé

Ce que le déclarant ne voit jamais

- Les messages **internes** et **restreints**, même sur son propre dossier.
- Le dossier d'origine lorsqu'on lui répond **doublon**.
- Qui a proposé, discuté ou signé sa récompense : il en voit le montant et l'état d'avancement, jamais la délibération.
- Les dossiers des autres, y compris ceux qui visent la même organisation.
- Le journal d'audit, les tableaux de bord et les exports.

Sa réputation, s'il est inscrit

La réputation dérive exclusivement d'événements produits par le traitement : elle n'est jamais saisie à la main, ni modifiable par le chercheur. Un rapport validé rapporte les points de base ; une sévérité élevée ou critique ouvre un bonus ; un doublon ne rapporte rien ; un comportement abusif retire des points. Le barème est un paramètre de déploiement, pas une constante du code.

MISE EN SITUATION

13. Trois parcours de bout en bout

Les mêmes règles, vues du début à la fin, sur trois dossiers typiques. Les jours sont indicatifs : ils illustrent des délais tenus.

13.1 Un citoyen signale un site ministériel

Un agent d'un ministère constate que le portail de son service affiche les dossiers d'autres usagers en changeant un numéro dans l'adresse. Il n'a pas de compte et préfère ne pas en créer, mais laisse une adresse de contact.

Jour	Qui	Ce qui se passe	État du dossier
J+0	Le citoyen	Dépose sur /report/ : description, adresse concernée, capture d'écran. Laisse une adresse de contact, accepte la politique.	SUBMITTED
J+0	Plateforme	Ouvre EVDP-2026-000412, arme les échéances 72 h et 5 jours, prévient l'équipe de triage, envoie l'accusé de dépôt.	SUBMITTED
J+1	Agent de triage	Lit le rapport, le juge exploitable, accuse réception.	RECEIVED puis ACKNOWLEDGED
J+2	Analyste CSIRT	S'assigne le dossier, reproduit la faille, qualifie : sévérité Élevée , vecteur CVSS, CWE-639, rattache le dossier au ministère.	TRIAGE
J+2	Analyste CSIRT	Valide. La date de divulgation est calculée à J+92 et l'échéance de correction de 30 jours s'arme.	VALIDATED
J+3	Analyste CSIRT	Contacte le ministère : la DSI et le contact sécurité sont déjà participants du dossier.	VENDOR_CONTACTED
J+5	DSI du ministère	Accuse réception, annonce un correctif sous quinze jours.	VENDOR_ACKNOWLEDGED
J+18	DSI du ministère	Déploie le contrôle d'accès manquant et déclare le correctif.	REMEDIATION puis FIX_AVAILABLE
J+20	Analyste CSIRT	Vérifie : la manipulation ne fonctionne plus.	VERIFICATION puis FIX_VERIFIED
J+21	Coordinateur national	Juge qu'un advisory public n'apporterait rien - défaut de configuration propre à une application interne - et clôt le dossier.	CLOSED
J+21	Le citoyen	Reçoit le courriel de clôture. Il aura été informé à chaque étape, sans jamais créer de compte.	-

13.2 Un chercheur inscrit, dossier publié avec CVE

Une chercheuse inscrite, identité publique, découvre une injection SQL non authentifiée sur un téléservice d'un établissement public. Elle demande un CVE et souhaite être créditée.

Jour	Qui	Ce qui se passe	État du dossier
J+0	La chercheuse	Dépose depuis son compte, joint une preuve de concept, coche la demande de CVE et le crédit public.	SUBMITTED
J+0	Plateforme	Ouvre le dossier et la redirige dessus : elle y suivra tout.	SUBMITTED
J+1	Analyste CSIRT	Accuse réception, s'assigne le dossier.	ACKNOWLEDGED
J+2	Analyste CSIRT	Demande une précision sur l'environnement de test.	NEEDS_INFORMATION
J+2	La chercheuse	Répond dans la messagerie du dossier, au niveau Participants.	NEEDS_INFORMATION
J+3	Analyste CSIRT	Reprend le triage : sévérité Critique , CVSS 9.8, CWE-89. Valide. La chercheuse reçoit ses points de réputation, majorés.	TRiage puis VALIDATED
J+3	Analyste CSIRT	Contacte l'établissement. Ouvre un fil interne pour l'analyse d'impact : la chercheuse ne le voit pas.	VENDOR_CONTACTED
J+6	Responsable d'organisation	Accuse réception et engage la correction.	VENDOR_ACKNOWLEDGED puis REMEDIATION
J+24	Plateforme	Alerte échéance proche à 80 % des 30 jours : l'équipe et l'entité sont prévenues.	REMEDIATION
J+27	DSI	Livre le correctif en production.	FIX_AVAILABLE
J+29	La chercheuse	Sollicitée par message, confirme que l'injection n'est plus exploitable.	VERIFICATION
J+29	Analyste CSIRT	Entérine la vérification, associe le CVE obtenu, planifie la divulgation à J+45.	FIX_VERIFIED puis DISCLOSURE_SCHEDULED
J+31	Analyste CSIRT	Rédige l'advisory depuis le dossier : brouillon assaini, sans preuve de concept ni étapes de reproduction. Passe en relecture.	DISCLOSURE_SCHEDULED
J+38	Coordinateur national	Relit, approuve, vérifie le crédit et la chronologie publique.	DISCLOSURE_SCHEDULED
J+45	Coordinateur national	Publie l'advisory. La chercheuse reçoit le lien ; son nom y figure.	PUBLISHED
J+46	Analyste CSIRT	Clôt le dossier ; les échéances restantes sont annulées.	CLOSED

13.3 Un chercheur Bug Bounty récompense

Un chercheur Bug Bounty, compte vérifié, travaille sur un programme ouvert par une entreprise publique. Il trouve un contournement d'authentification sur une API listée au périmètre.

Jour	Qui	Ce qui se passe	État du dossier
J+0	Le chercheur	Lit le périmètre, les règles et la grille, puis dépose depuis la fiche du programme. Le programme est pré-sélectionné.	SUBMITTED
J+0	Plateforme	Vérifie compte et adresse vérifiée, ouvre le dossier sur le workflow Bug Bounty .	SUBMITTED
J+1	Agent de triage	Accuse réception.	ACKNOWLEDGED
J+2	Analyste CSIRT	Qualifie : sévérité Critique , et retient l' actif API de production - qui a sa propre grille de récompense. Valide.	TRIAGE puis VALIDATED
J+2	Analyste CSIRT	Attribue la sévérité définitive au titre du programme.	SEVERITY_ASSIGNED
J+3	Analyste CSIRT	Propose une récompense : la plateforme suggère la borne haute du palier de l'actif. Le chercheur est notifié de la proposition.	BOUNTY_REVIEW
J+4	Responsable d'organisation	Donne un avis favorable et confirme l'impact métier.	BOUNTY_REVIEW
J+5	Coordinateur national	Approuve le montant - l'analyste qui l'a proposé n'en a pas le droit - et signe la décision.	REWARD_APPROVED
J+5	Analyste CSIRT	Bascule le dossier en correction ; la récompense suit son cours séparément.	REMEDIATION
J+12	Service financier	Verse la récompense hors plateforme.	REMEDIATION
J+12	Coordinateur national	Enregistre le versement : montant, moyen, référence. Le chercheur est notifié et son cumul perçu est mis à jour.	REMEDIATION
J+19	DSI	Corrige et déclare le correctif.	FIX_AVAILABLE
J+21	Analyste CSIRT	Fait vérifier par le chercheur, puis entérine.	VERIFICATION puis FIX_VERIFIED
J+60	Coordinateur national	Publie l'advisory à la date convenue, puis le dossier est clos.	PUBLISHED puis CLOSED

CE QUI RESTE ÉCRIT

14. Traçabilité et contrôle

Chaque acte du traitement laisse trois traces distinctes, qui ne servent pas au même usage.

Trace	Contenu	Qui la lit
Chronologie du dossier	Les jalons métiers : rapport reçu, accusé de réception, validation, organisation contactée, correctif fourni et vérifié, divulgation, publication, clôture. Certains sont marqués publics et alimentent l'advisory.	Tous les participants
Historique des statuts	Chaque transition : état de départ, état d'arrivée, auteur, date, commentaire.	Les participants du dossier
Journal d'audit	Connexions et échecs, consultations de dossier, modifications, messages, pièces jointes téléversées et téléchargées, décisions de récompense, publications, exports - et les refus .	Coordinateur national, auditeur

Un refus laisse une trace, même quand l'action échoue

Lorsqu'une transition interdite est tentée, le contrôle a lieu **hors transaction** : l'écriture de la trace ne peut pas être annulée par le rejet de l'action. Un dossier où l'on voit dix transitions refusées en cinq minutes raconte quelque chose - encore faut-il que la trace survive.

Cinq règles que la plateforme fait respecter d'elle-même

- **Isolation.** Chaque requête de dossier est filtrée par le périmètre du compte : un déclarant ne voit que ses dossiers, une organisation que les siens. Le filtre est appliqué au niveau des données, pas de l'affichage.
- **Dossier introuvable plutôt qu'accès refusé.** Un dossier hors périmètre répond **introuvable** : confirmer son existence serait déjà une information.
- **Lecture seule réelle.** Le rôle d'auditeur est refusé à l'écriture par le serveur, action par action.
- **Le rapport d'origine n'est jamais modifié.** La qualification vit sur le dossier ; ce que le déclarant a écrit reste tel quel.
- **Aucune publication implicite.** Aucun champ du rapport ne devient public par défaut : l'advisory est une rédaction distincte, relue et approuvée.

ANNEXE

A. Les états du dossier

Vingt-quatre états, dont trois propres au Bug Bounty. La colonne **Autorisation** indique la capacité exigée pour y conduire un dossier, au-delà de CHANGE_CASE_STATUS.

État	Signification	Autorisation
DRAFT	Brouillon non soumis	-
SUBMITTED	Rapport soumis, en attente de prise en charge	-
RECEIVED	Réception enregistrée par l'équipe	CHANGE_CASE_STATUS
ACKNOWLEDGED	Accusé de réception envoyé au déclarant	CHANGE_CASE_STATUS
TRIAGE	Qualification technique en cours	CHANGE_CASE_STATUS
NEEDS_INFORMATION	Informations complémentaires demandées	CHANGE_CASE_STATUS
VALIDATED	Vulnérabilité confirmée	TRIAGE_CASE
SEVERITY_ASSIGNED	Sévérité attribuée (Bug Bounty)	SET_SEVERITY
BOUNTY_REVIEW	Revue de récompense (Bug Bounty)	PROPOSE_BOUNTY
REWARD_APPROVED	Récompense approuvée (Bug Bounty)	APPROVE_BOUNTY
DUPLICATE	Doublon d'un dossier existant - terminal	TRIAGE_CASE
REJECTED	Non retenue - terminal	TRIAGE_CASE
OUT_OF_SCOPE	Hors périmètre du programme - terminal	TRIAGE_CASE
NOT_APPLICABLE	Sans objet - terminal	TRIAGE_CASE
INFORMATIVE	Information utile, sans vulnérabilité exploitable	TRIAGE_CASE
IN_PROGRESS	Prise en charge engagée	CHANGE_CASE_STATUS
VENDOR_CONTACTED	Organisation affectée contactée	CHANGE_CASE_STATUS
VENDOR_ACKNOWLEDGED	L'organisation a accusé réception	CHANGE_CASE_STATUS
REMEDIATION	Correction en cours	CHANGE_CASE_STATUS
FIX_AVAILABLE	Correctif disponible	CHANGE_CASE_STATUS
VERIFICATION	Vérification du correctif	CHANGE_CASE_STATUS
FIX_VERIFIED	Correctif vérifié	CHANGE_CASE_STATUS
DISCLOSURE_SCHEDULED	Date de divulgation fixée	CHANGE_CASE_STATUS
PUBLISHED	Advisory publié	PUBLISH_ADVISORY
CLOSED	Dossier clos - terminal	CHANGE_CASE_STATUS

ANNEXE

B. Ce qui se règle sans toucher au code

Les valeurs citées dans ce manuel sont celles livrées par défaut. Toutes se modifient par l'administration ou par la configuration du déploiement.

Réglage	Où	Effet
Délais d'accusé de réception, de triage, de réponse de l'organisation, de correction	Administration, politiques de délai	S'appliquent aux nouveaux dossiers ; un programme peut avoir sa propre politique.
Seuil d'alerte (80 %)	Politique de délai	Détermine le moment de l'avertissement avant dépassement.
Délai de divulgation (90 jours)	Fiche du programme	Sert au calcul de la date de divulgation à la validation.
Matrice de récompense	Fiche du programme	Paliers par sévérité, affinables par actif ; devise et budget.
Barème de réputation	Configuration du déploiement	Points de validation, bonus de sévérité, pénalité d'abus.
Exigence d'adresse vérifiée et sursis	Fiche du programme, configuration	Conditionne la participation aux programmes ; le sursis ne vise que les comptes antérieurs à la bascule.
Politique de divulgation publique	Administration, paramètres du site	Texte affiché sur /disclosure-policy/ et rappelé au dépôt.
Extensions et taille des pièces jointes	Configuration du déploiement	Liste autorisée, liste interdite, plafond.

Pour aller plus loin

Ce manuel décrit le processus. La documentation technique du dépôt le complète : **docs/cvd-workflow.md** pour la machine à états, **docs/bug-bounty.md** pour les programmes et les récompenses, **docs/administration.md** pour l'exploitation courante, **docs/security.md** pour le modèle de menaces, **docs/api.md** pour l'interface programmatique.